

Informe Técnico: Auditoría de Seguridad y Análisis Automático de Vulnerabilidades Perimetrales

Este informe documenta la evaluación de seguridad, metodología de escaneo perimetral y el análisis profundo de hallazgos críticos detectados sobre un nodo de desarrollo expuesto (Metasploitable 3) utilizando el motor de escaneo automatizado Tenable Nessus Essentials.

1. Metodología y Configuración de la Evaluación (Escaneo No Autenticado)

La auditoría se estructuró bajo la modalidad de caja negra (escaneo no autenticado) con el fin de determinar de forma estricta la superficie de ataque expuesta hacia la red interna y los vectores explotables desde una perspectiva externa, mapeando los banners de puertos y las cabeceras de transporte (Capa 3 y Capas superiores).

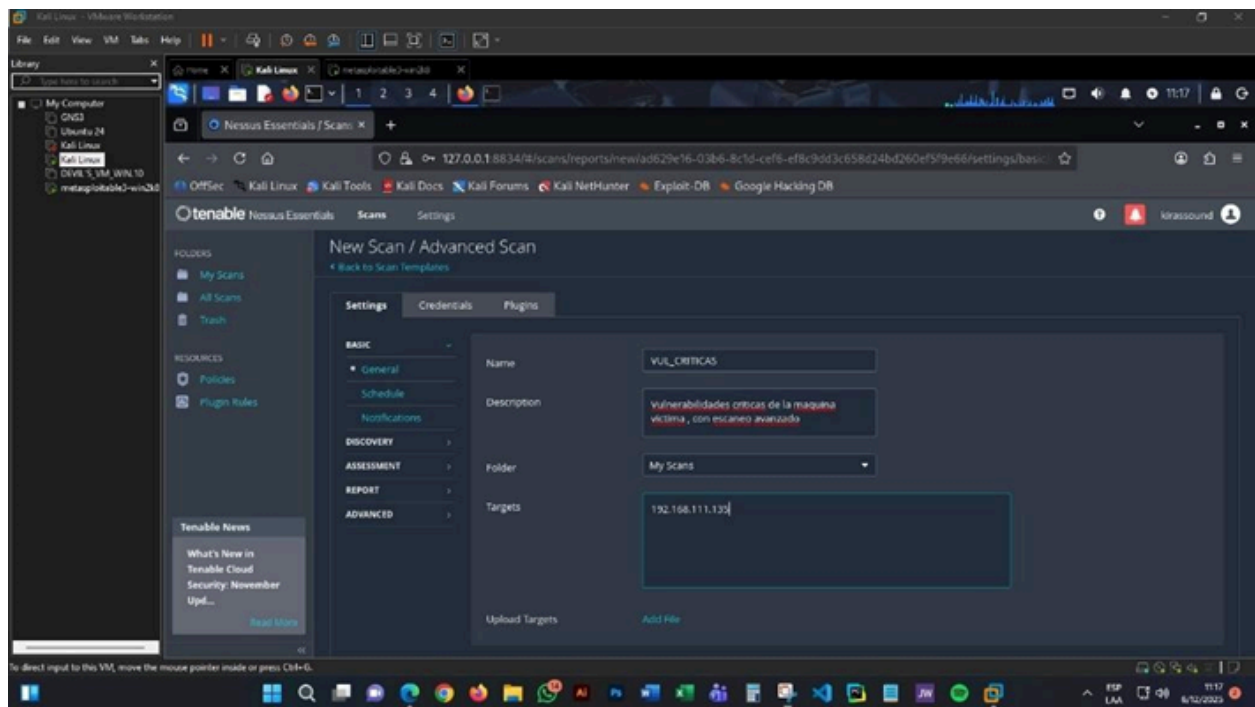
1.1. Parámetros de Configuración del Motor

- **Fase de Descubrimiento:** Inyección ICMP activa y validación mutua de sockets de transporte .
- **Rango de Puertos Auditados:** Análisis completo sobre el espectro total de puertos lógicos TCP/UDP (1 - 65535).
- **Políticas de Escaneo:** Configuración avanzada de directivas (Advanced Scan) para evasión básica de falsos positivos mediante correlación de banners de servicios .

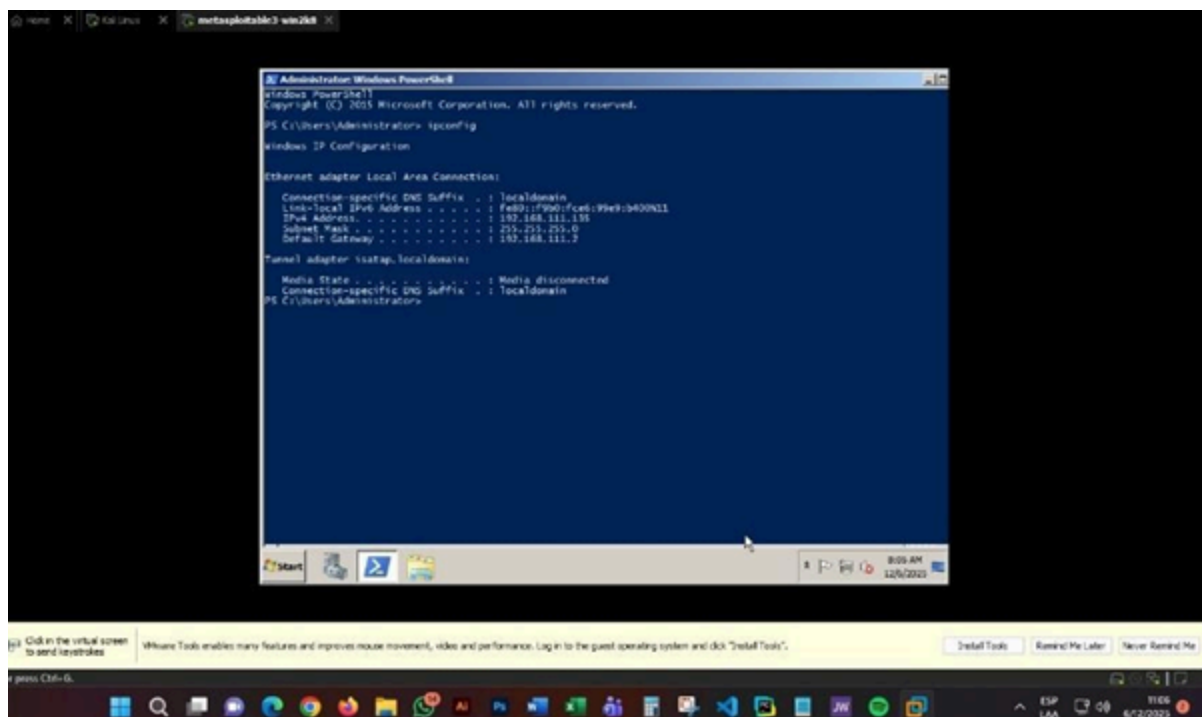
Verificación de conectividad perimetral y estado activo del demonio de Nessus

```
$ sudo systemctl status nessusd.service
```

```
$ ping -c 4 192.168.111.135
```



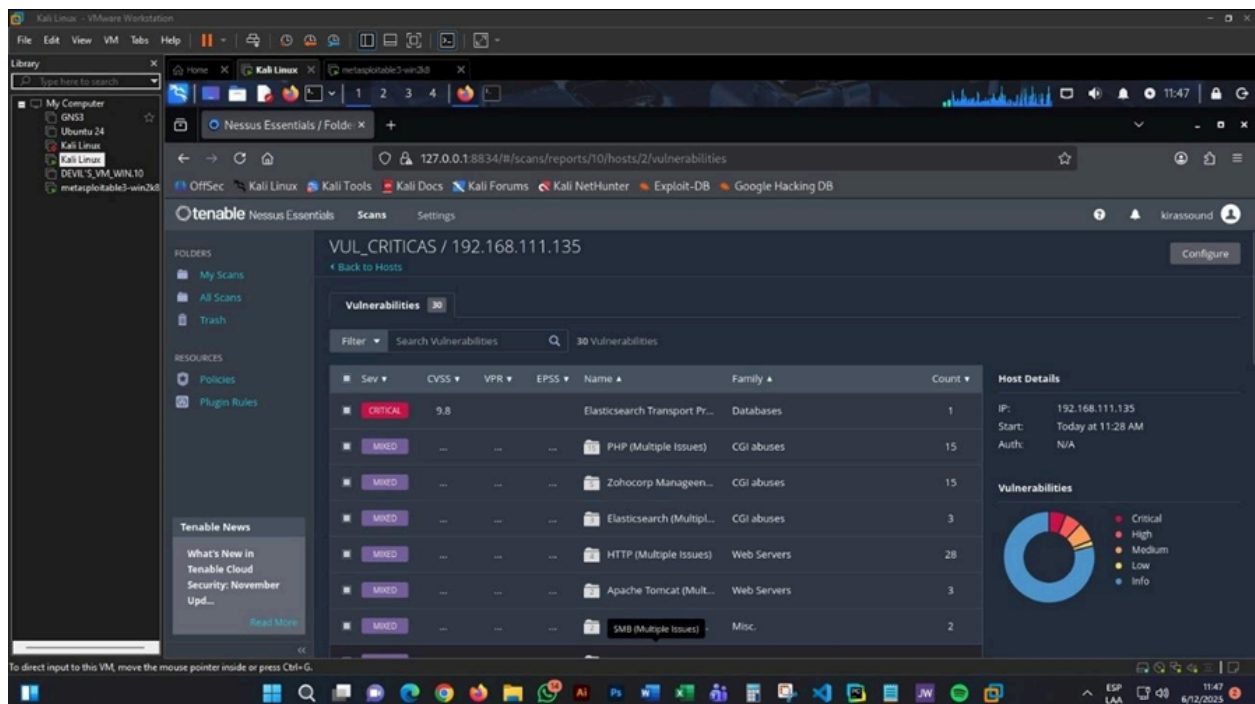
Capturas de pantalla de la tarea de configuración y de escaneo completadas en Nessus



Comunicación ICMP entre máquina Metasploitable

```
kirassound@kali: ~  
Session Acciones Editar Vista Ayuda  
Active: active (running) since Sat 2025-12-06 10:47:44 -05; 2min 42s ago  
Invocation: 338c3556388d45efae97c99fa8dd44a4  
Main PID: 1062 (nessus-service)  
Tasks: 17 (limit: 3237)  
Memory: 1.5G (peak: 1.6G)  
CPU: 1min 48.994s  
CGroup: /system.slice/nessusd.service  
└─1062 /opt/nessus/sbin/nessus-service -q  
└─1088 nessusd -q  
  
dic 06 10:47:44 kali systemd[1]: Started nessusd.service - The Nessus Vulnerability Scanner.  
dic 06 10:47:45 kali nessus-service[1062]: nessus-service [1062][INFO] : Nessus Service Starting  
  
(kirassound@kali)-[~]  
$ ping 192.168.111.135  
PING 192.168.111.135 (192.168.111.135) 56(84) bytes of data.  
64 bytes from 192.168.111.135: icmp_seq=1 ttl=128 time=0.496 ms  
64 bytes from 192.168.111.135: icmp_seq=2 ttl=128 time=0.389 ms  
64 bytes from 192.168.111.135: icmp_seq=3 ttl=128 time=0.237 ms  
64 bytes from 192.168.111.135: icmp_seq=4 ttl=128 time=0.284 ms  
64 bytes from 192.168.111.135: icmp_seq=5 ttl=128 time=0.251 ms  
64 bytes from 192.168.111.135: icmp_seq=6 ttl=128 time=0.295 ms  
64 bytes from 192.168.111.135: icmp_seq=7 ttl=128 time=0.256 ms  
64 bytes from 192.168.111.135: icmp_seq=8 ttl=128 time=0.371 ms  
64 bytes from 192.168.111.135: icmp_seq=9 ttl=128 time=0.281 ms  
64 bytes from 192.168.111.135: icmp_seq=10 ttl=128 time=0.295 ms
```

Comunicación ICMP entre máquina Kali Linux



Escaneo completado en Nessus

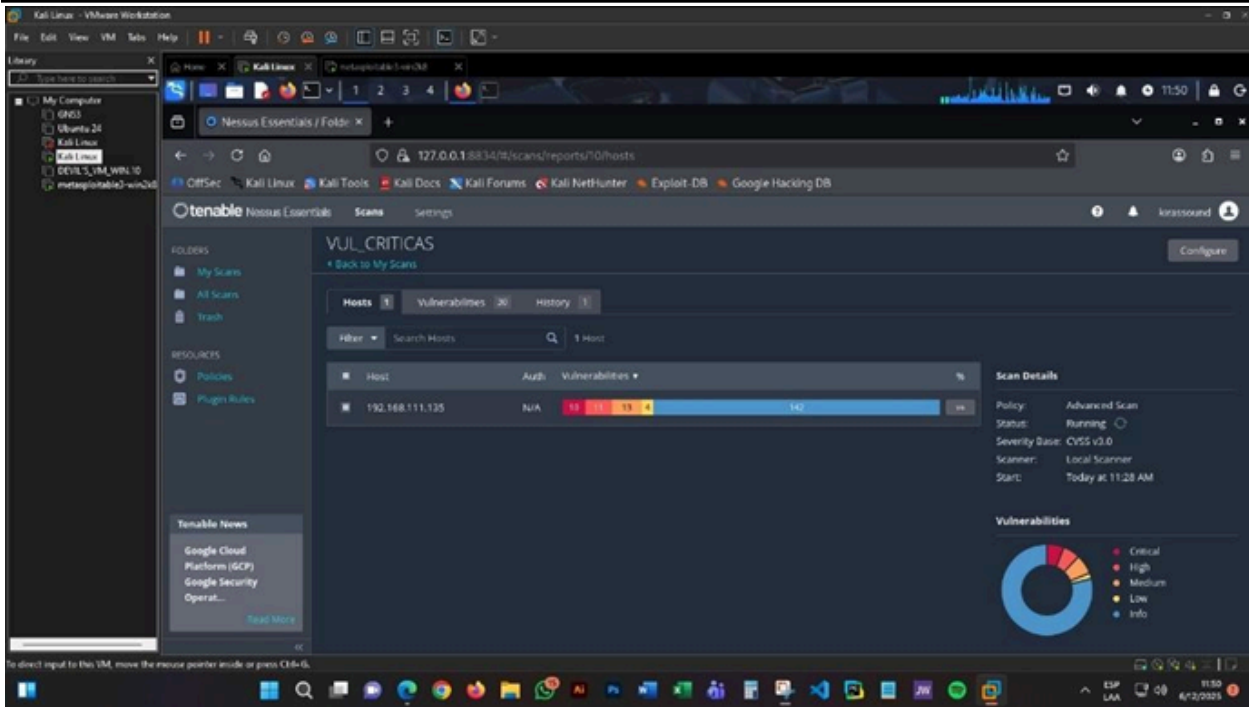
2. Matriz de Vulnerabilidades Críticas Identificadas (CVSS > 7.0)

A través del motor de correlación de firmas de Nessus, se aislaron vulnerabilidades críticas que comprometen la integridad, confidencialidad y disponibilidad del servidor de pruebas bajo el marco del Common Vulnerability Scoring System (CVSS) .

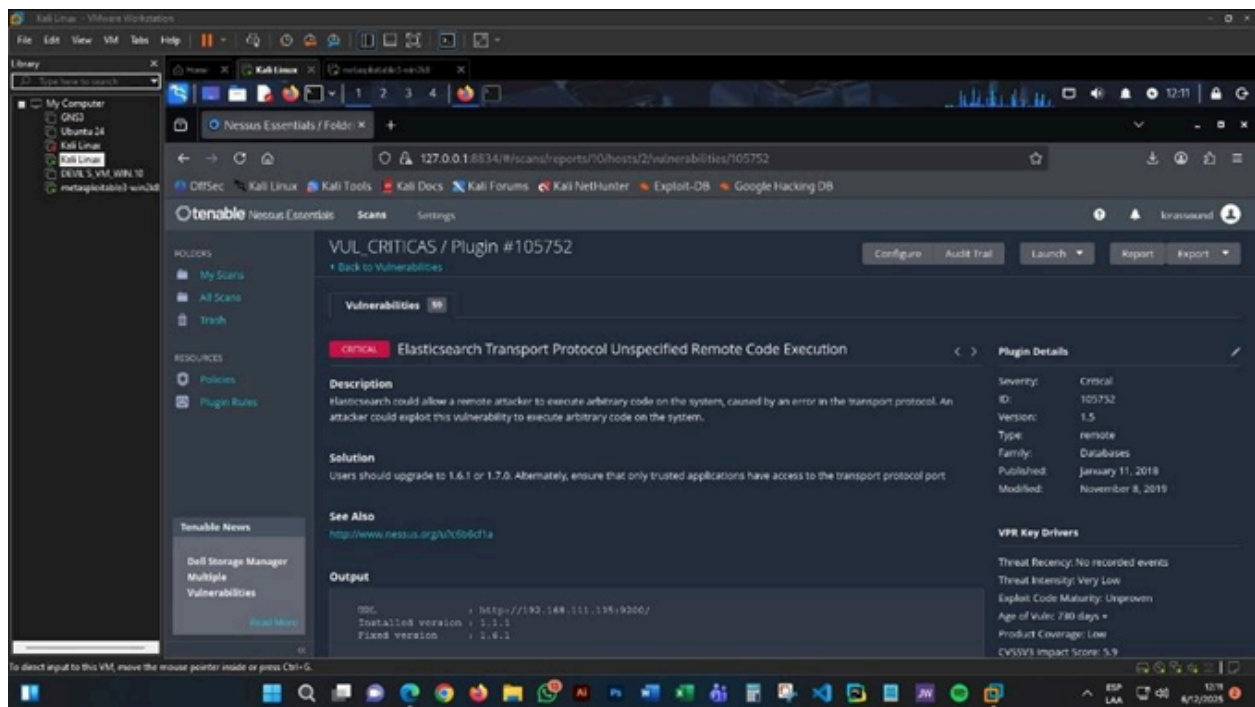
Nombre de la Vulnerabilidad	CVSS	Puerto / Servicio	Descripción Técnica	Recomendación de Remediación
Elasticsearch Transport Protocol RCE	9.8 (Crítica)	9200 / TCP Elasticsearch [cite: 10]	Un fallo severo en el protocolo de transporte interno de Elasticsearch permite que un atacante remoto no autenticado inyecte y ejecute código arbitrario directamente en el contexto de seguridad del servidor [cite: 10].	Actualizar el motor Elasticsearch a una versión superior a la 1.6.1 o implementar listas de control de acceso (ACL) para restringir el puerto a hosts locales confiables.
Apache Tomcat End of Life (EOL)	10.0 (Crítica)	8282 / TCP HTTP [cite: 10]	La instancia de Apache Tomcat detectada corresponde a la rama 8.0.x, la cual ha alcanzado el Fin de Vida Útil (EOL). El software carece de parches oficiales, quedando vulnerable de forma indefinida a exploits públicos [cite:	Ejecutar la migración inmediata de los servicios de contenedores Java hacia versiones estables y con soporte activo (Tomcat 9.x o Tomcat 10.x) [cite: 10].

Nombre de la Vulnerabilidad	CVSS	Puerto / Servicio	Descripción Técnica	Recomendación de Remediación
			10].	
Apache Tomcat Multiple Vulnerabilities	10.0 (Crítica)	8282 / TCP HTTP [cite: 10]	Versiones de Apache Tomcat anteriores a la 8.0.39 sufren de múltiples fallas concurrentes que facilitan la ejecución remota de código (RCE), desborde de búfer en peticiones HTTP y exposición no autorizada mediante JMX [cite: 10].	Aplicar parche de seguridad urgente actualizando a la versión 8.0.39 o superior, deshabilitando interfaces de administración no esenciales [cite: 10].
SSL/TLS Logjam Vulnerability (CVE-2015-4000)	— (Alta)	443 / HTTPS [cite: 10]	Fallo de diseño en el intercambio de claves criptográficas Diffie-Hellman que emplea parámetros reducidos o reutilizados, permitiendo a un atacante con capacidades Man-in-the-Middle (MitM) forzar una degradación del cifrado a TLS export-grade [cite: 10].	Deshabilitar suites de cifrado de exportación, reconfigurar el servidor web para rechazar grupos DH menores a 2048 bits y parametrizar curvas elípticas modernas [cite: 10].
Microsoft Windows Server 2008 EOL	— (Crítica)	445 / SMB [cite: 10]	El sistema operativo base del host objetivo se encuentra fuera de soporte oficial (End of	Diseñar e implementar un plan de migración tecnológica inmediato hacia

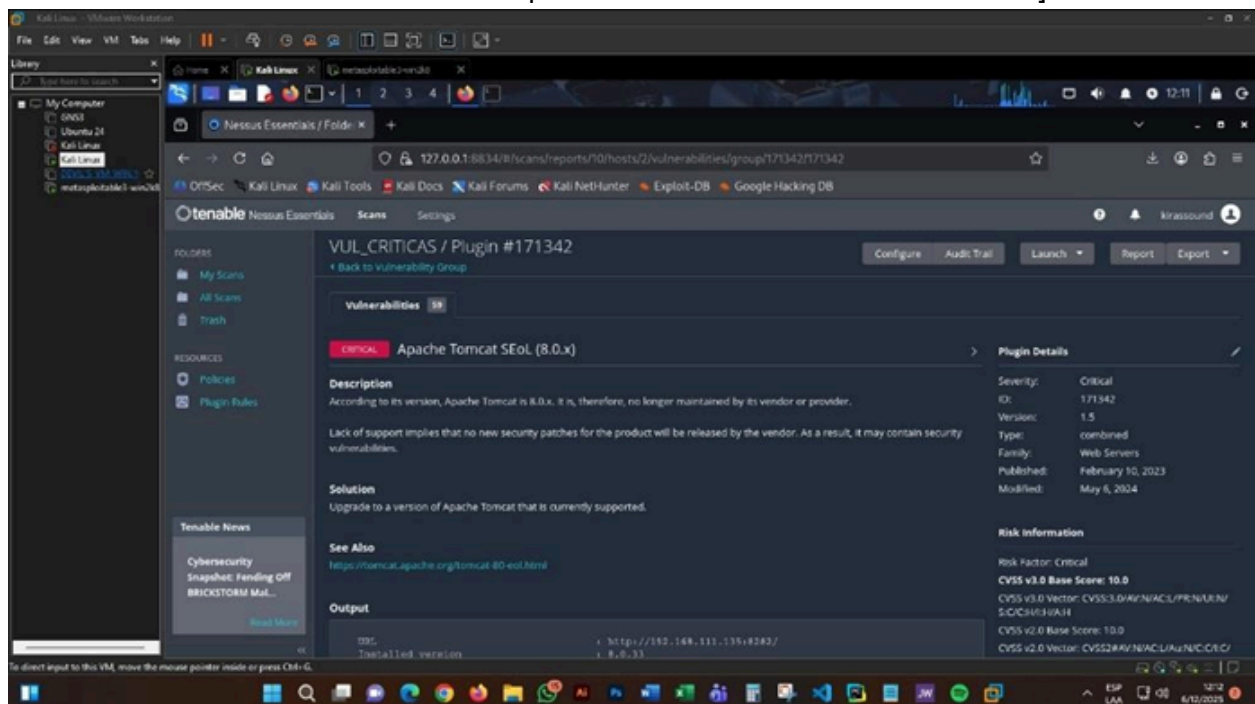
Nombre de la Vulnerabilidad	CVSS	Puerto / Servicio	Descripción Técnica	Recomendación de Remediación
			Life), lo que anula la recepción de actualizaciones críticas y expone el perímetro a exploits de ejecución remota como EternalBlue (MS17-010) [cite: 10].	una plataforma de sistema operativo vigente (Windows Server 2019 / 2022 o distribución Linux de producción) [cite: 10].



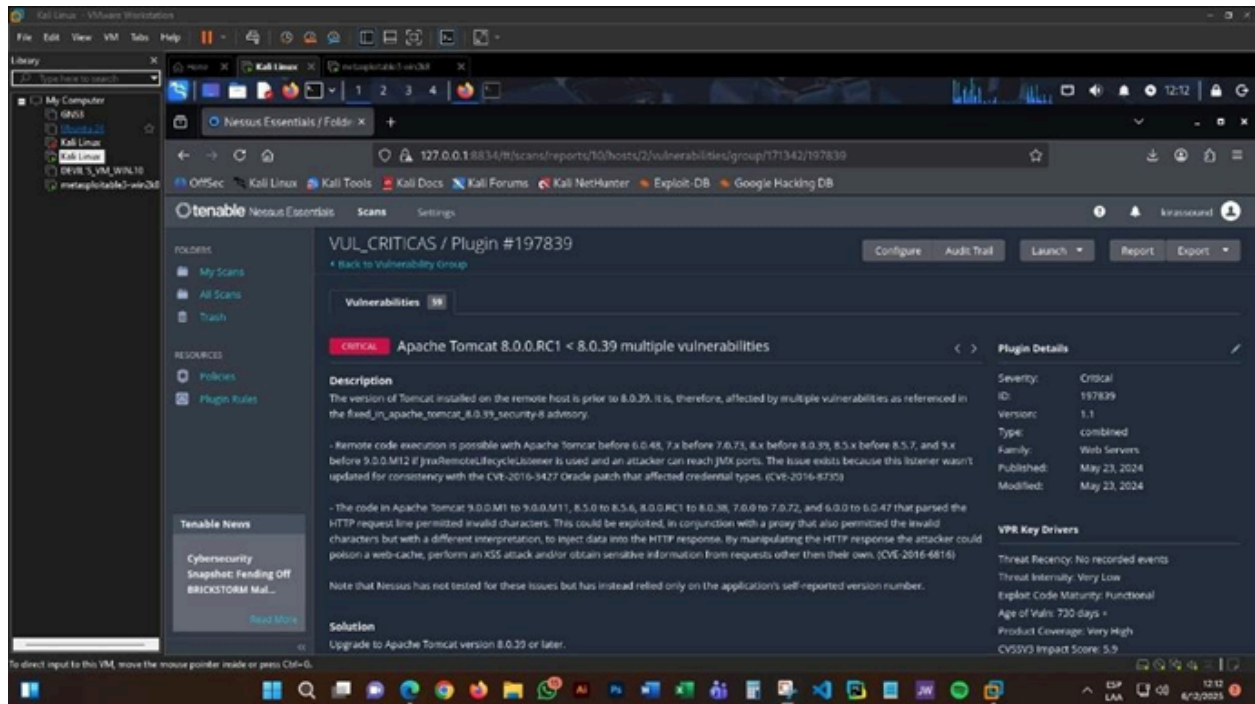
Lista de vulnerabilidades de la máquina Metasploit 3



Vulnerabilidad N°1 - Elasticsearch Transport Protocol - Remote Code Execution]



Vulnerabilidad N°2 - Apache Tomcat SEoL (8.0.x)]



Vulnerabilidad N°3 - Apache Tomcat 8.0.0.RC1 < 8.0.39 Multiple Vulnerabilities]

3. Análisis por Vectores de Ataque

3.1. Vulnerabilidades Asociadas a Servicios Web

El análisis determinó que el 100% de las fallas críticas de software (Tomcat Default Files, Tomcat Multiple Vulnerabilities, Elasticsearch REST API y SSL/TLS Logjam) comprometen directamente la pila de protocolos HTTP/HTTPS [cite: 10]. Al estar estos servicios expuestos públicamente hacia redes de desarrollo, constituyen los puntos de entrada primarios (vectores de intrusión inicial) para comprometer la infraestructura antes de alcanzar capas de red internas [cite: 10].

3.2. Exposición por Autenticación Débil y Archivos por Defecto

La presencia de directorios raíces e interfaces de administración con credenciales de fábrica o configuraciones predeterminadas (Tomcat Root/Manager pages) permite a un atacante automatizar tareas de reconocimiento táctico [cite: 10]. La obtención de metadatos precisos (versiones exactas de compilación expuestas en los banners) elimina la necesidad de ejecutar ataques de fuerza bruta tradicionales, facilitando la selección directa del exploit público idóneo [cite: 10].

4. Diagnóstico Técnico y Plan de Remediación Priorizado

- **Prioridad 1 (Crítica Absoluta):** Remediación inmediata de las fallas de Ejecución

Remota de Código (RCE) sin autenticación en Apache Tomcat y Elasticsearch mediante la actualización a versiones estables y el aislamiento perimetral de los puertos de gestión (8282 y 9200) mediante reglas estrictas en el firewall [cite: 10].

- **Prioridad 2 (Alta):** Mitigación de la vulnerabilidad criptográfica Logjam a través del fortalecimiento del handshake TLS (hardening de cifrado) y la eliminación definitiva de archivos y manuales predeterminados de los directorios públicos del servidor web [cite: 10].
- **Prioridad 3 (Ciclo de Vida):** Ejecución del plan de migración tecnológica del sistema operativo Windows Server 2008 EOL hacia plataformas modernas con soporte de ciclo de vida activo para erradicar la exposición estructural a nivel de núcleo [cite: 10].

4.1. Limitaciones Técnicas del Enfoque No Autenticado

El escaneo perimetral sin credenciales limita el análisis exclusivamente a los vectores visibles a nivel de red, omitiendo la auditoría interna del sistema (hardening del kernel, configuraciones locales de políticas de contraseñas, parches parciales aplicados a nivel de registro de Windows o auditorías de software local) [cite: 10]. Es mandatorio complementar este reporte con un escaneo autenticado para correlacionar la seguridad interna con la robustez perimetral [cite: 10].